codigo.sh

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Worked for 1s >

Este arquivo é malware.

Análise passo a passo

1. **Download de payload remoto**
   O script define a URL `http://23.252.123.134:18095/fleet_lin.tgz` e tenta baixar o arquivo `f.tgz` usando, em ordem de preferência:
   - `curl`
   - `wget`
   - `python3`
   - `python`
     O download é feito de forma silenciosa (`-s` , `-q` , redirecionamento de erros) e com timeout de 240 segundos.
2. **Criação de diretório oculto**
   Cria um diretório temporário com nome ofuscado: `/tmp/.qc$$` (o `$$` é o PID do processo, tornando o nome único e menos óbvio). Se falhar, cai para `/tmp` .
3. **Extração do arquivo**
   Extrai o conteúdo do `.tgz` com `tar xzf` . Se a extração falhar, o script encerra com a mensagem `NOTAR` .
4. **Personalização do minerador**
   Obtém o hostname da máquina (primeiros 12 caracteres) e substitui a string `RIGNAME` no arquivo `config.json` pelo hostname. Isso é típico de mineradores de criptomoeda (XMRig e variantes), que usam o nome da máquina como identificador do “rig”.
5. **Execução em background**
   Executa `sh run.sh` em segundo plano:
   - Preferencialmente com `setsid` (desvincula o processo do terminal/sessão)
   - Ou simplesmente com `&`
     A saída é totalmente descartada (`>/dev/null 2>&1`).
6. **Verificação de processos**
   Após 10 segundos, verifica se os processos `c` e `x` estão rodando dentro do diretório `.qc*` (usando `pgrep` e `ps`). Esses nomes curtos e genéricos são comuns em binários de mineradores ofuscados.
7. **Saída de status**
   Imprime uma mensagem de conclusão contendo hostname, se o download funcionou, o diretório usado e quais processos foram encontrados (`LITE_DONE ...`).

Conclusão

O script é um **dropper/loader de malware**, especificamente um minerador de criptomoeda (crypto-miner). Ele:

- Baixa um payload de um servidor externo não confiável
- Extrai e configura o minerador com o nome da máquina
- Executa o minerador de forma persistente e silenciosa em background
- Usa técnicas de ofuscação (diretório oculto, nomes curtos de processo, execução desvinculada)

Não há nenhuma funcionalidade legítima. O comportamento é clássico de campanhas de cryptojacking em servidores Linux.

↘ Como remover o malware e garantir que não volte

↘ O que é o arquivo run.sh?

↘ Como remover este malware